Microsoft Purview Compliance Manager Implementation

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Microsoft Purview Compliance Manager Implementation 4
What you get . . . 4
Why it matters . . . 4
The bottom line . . . 5
1. Solution Overview — Microsoft Purview Compliance Manager Implementation 5
What this solution is . . . 5
Why this matters . . . 5
How it works . . . 6
The four building blocks (what Compliance Manager gives you) . . . 7
The role-separation model (least privilege) . . . 7
What you can control . . . 7
Limitations (be honest with buyers) . . . 8
Naming convention (used in every doc and script) . . . 8
The standard deployment model . . . 9
2. Requirements Guide — Microsoft Purview Compliance Manager Implementation 9
2.1 Licensing — base Compliance Manager and premium/custom templates . . . 9
2.2 Compliance Manager role groups populated with least-privilege separation . . . 10
2.3 Named compliance, records, privacy & legal owners (applicability + adequacy) . . . 10
2.4 In-scope assessment templates and grouping decided . . . 10
2.5 Improvement-action owners and evidence sources identified . . . 10
2.6 Automatic-testing decision and the underlying technical signals . . . 11
2.7 Security & Compliance PowerShell + Microsoft Graph toolchain . . . 11
2.8 A pilot assessment and change control . . . 11
Global Requirements — Microsoft Purview Solutions 11
1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 12
2. Purview roles (least-privilege) and portal access . . . 12
3. Security & Compliance PowerShell + Graph toolchain . . . 12
4. Data sources & scope in scope . . . 13
5. Compliance, records, privacy & legal stakeholders . . . 13
6. A pilot scope and change control . . . 13
3. Implementation Guide — Microsoft Purview Compliance Manager Implementation 14
Step 1 — Baseline the score and capture the role/licensing readiness (Assess) . . . 14
Step 2 — Assign roles with least-privilege separation (Configure — guardrails) . . . 15
Step 3 — Design the in-scope assessments, grouping, and owners (Design) . . . 15
Step 4 — Create the pilot assessment (Configure — pilot-first) . . . 15

Step 5 — Build the improvement-action plan and evidence register (Configure) . . . 16
Step 6 — Enable automatic testing where it applies (Configure) . . . 16
Step 7 — Validate the evidence behind the actions (Pilot → Validate) . . . 16
Step 8 — Expand to the full assessment set and run the cadence (Expand) . . . 17
5. Testing Guide — Microsoft Purview Compliance Manager Implementation 17
Test 1 — Role separation is in place (the access guardrail) . . . 18
Test 2 — Licensing supports the in-scope templates . . . 18
Test 3 — The pilot assessment exists and is scored . . . 18
Test 4 — Every pilot action has an owner, target date, status, and evidence source . . . 18
Test 5 — Automatic testing reflects the real technical state (true evidence) . . . 18
Test 6 — A not-yet-implemented control scores as such (no false pass) . . . 18
Test 7 — Manual evidence is attached and defensible . . . 18
Test 8 — Control mapping / shared controls behave as expected . . . 19
Test 9 — Posture report is accurate and complete . . . 19
Test 10 — Safe automation defaults . . . 19
6. Troubleshooting Guide — Microsoft Purview Compliance Manager Implementation 19
Compliance Manager isn't visible, or a template can't be created . . . 19
A Compliance Manager role group is missing (`Get-RoleGroup` returns nothing) . . . 20
The same person is both an Administrator and a Contributor (separation note) . . . 20
`CMPMGR-Configuration.ps1` didn't write any files . . . 20
`CMPMGR-Configuration.ps1` reports validation issues . . . 20
The Compliance Score looks wrong or hasn't moved after implementing a control . . . 20
An action shows "Implemented" but the control isn't actually there (false pass) . . . 20
`CMPMGR-Validation.ps1` reports a control "Absent" that you believe is configured . . . 21
`Get-Label` / `Get-DlpCompliancePolicy` / `Get-RetentionCompliancePolicy` not recognised . . . 21
Automatic testing isn't updating any actions . . . 21
Shared control implemented once, but a second assessment still shows it not done . . . 21
`CMPMGR-Set-Scope.ps1 -Commit` fails to add/remove a member . . . 21
"Does this evidence satisfy the regulation? Are we compliant?" . . . 21
7. Best Practices — Microsoft Purview Compliance Manager Implementation 22
8. Deliverables Summary — Microsoft Purview Compliance Manager Implementation 23
Documentation . . . 23
PowerShell scripts . . . 24
Artifacts this solution creates (naming convention) . . . 25
Outcome . . . 25
Appendix A — PowerShell Scripts 26

Executive Summary — Microsoft Purview Compliance Manager Implementation

"Are we compliant?" has no defensible answer without a control-by-control assessment. Left to spreadsheets and memory, compliance status is a guess — a gap you discover in an audit, not before it. Microsoft Purview **Compliance Manager** turns that guess into a **measured, points-based Compliance Score** backed by evidence: **assessments** built from regulation/standard templates, **improvement actions** with owners and test status, **control mapping** so one fix scores across many frameworks, and an **evidence** store that produces the audit trail. This solution stands it up correctly, end to end.

This is a complete, deploy-it-today package for implementing Compliance Manager, written for a competent Microsoft 365 / compliance administrator and built to be run **with** the organization's compliance, records, privacy, and legal functions — who own **which** regulations apply and **whether** the evidence satisfies them.

What you get

- A plain-language **Solution Overview** of Compliance Manager — the four building blocks (**assessments, improvement actions, control mapping, evidence**), the score, the role-separation model, and the honest limits (it **measures, it doesn't enforce**; premium templates are licensing-gated; the portal is authoritative).
- A **Requirements Guide** with verify / implement-if-missing for every prerequisite: base vs **premium/custom** template licensing, the separated role groups, named governance owners, the in-scope templates and grouping, action owners and evidence sources, automatic testing, and the pilot.
- An **Implementation Guide** that baselines the score, assigns roles with least-privilege separation, creates a **pilot** assessment, builds the **action plan and evidence register**, enables **automatic testing**, validates the technical evidence, then expands to the full set — with pass/fail gates and rollback at every step, and any high-impact technical remediation **piloted in simulation/test first**.
- **Five PowerShell tools** (Security & Compliance PowerShell / Graph): readiness + role-separation + licensing discovery, an action-plan / evidence-register builder, a technical-evidence validator, a score-posture report, and a role-membership helper — **read-only or `-WhatIf` by default, no secrets**.
- **Testing** and **Best Practices** that prove ownership, evidence accuracy, control mapping, and separation before anything expands.

Why it matters

- **A score you can defend beats a status you assert.** Compliance Manager makes the number control-by-control and evidence-backed, so gaps are visible and owned before an auditor finds them.
- **Evidence is the point.** Owners, test dates, and proof attached to each action are what make the score credible — this solution makes producing that record routine, not a fire drill.
- **Fix once, score many.** Control mapping means a single well-implemented control satisfies

requirements across every framework that references it — the fastest path to a higher, honest score.

- **Measurement, not enforcement.** Compliance Manager changes nothing on the tenant; the technical remediations it recommends are separate, piloted changes — this solution keeps that boundary clear and safe.

The bottom line

Compliance turned into a **measured score** in Microsoft Purview — assessments created, improvement actions owned and tested, control mapping leveraged, and evidence attached and defensible — **delivered, validated, and audit-ready.** A fraction of the cost of a consulting engagement, self-guided and tested.

Compliance Manager premium/custom templates are licensing-dependent (Microsoft 365 E5 / E5 Compliance / Premium Assessment Add-On) and the Purview portal evolves; verify capability and template availability against your own licensing and tenant. Regulatory applicability and whether the evidence satisfies an obligation are deferred to your compliance, records, privacy, and legal functions.

1. Solution Overview — Microsoft Purview Compliance Manager Implementation

What this solution is

Compliance Manager is the Microsoft Purview capability that turns your compliance posture into a **measured, points-based score** you can manage. It provides **assessments** (a set of controls drawn from a regulation, standard, or internal policy, built from a **template**), **improvement actions** (the specific technical and operational steps that raise the score), **control mapping** (one action can satisfy a control that appears in many assessments), and an **evidence** store (documentation, test results, owners, and dates attached to each action). The result is a **Compliance Score** and a defensible record of what is implemented, by whom, tested when, with proof.

This solution is a repeatable, deploy-it-today way to stand Compliance Manager up correctly: capture the **baseline** score, design the **assessments and scope** with your compliance stakeholders, build the **improvement-action plan** with owners and evidence, turn on **automatic testing** where it applies, validate the technical evidence behind the actions, and then expand to the full assessment set with a maintenance cadence. It uses only the **Microsoft Purview portal**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** — no third-party tooling.

> ***Compliance Manager measures; it does not enforce.*** *Compliance Manager is an **assessment and scoring** tool — it reads your posture, recommends improvement actions, and records evidence. It does **not** change tenant configuration or block anything. The *technical* changes an improvement action recommends (enabling audit, DLP, MFA, retention, labels, etc.) are made in those features — and, because several are **high-impact**, they are **piloted in simulation/test first** under their own change control. This solution stands up the measurement, ownership, and evidence discipline; the enforcement of any given control is a separate, piloted change.*

Why this matters

• **Compliance status is a guess without a score.** "Are we compliant?" has no defensible answer without a control-by-control assessment. Compliance Manager makes it a **measured number** backed by evidence, so gaps are visible, owned, and tracked instead of discovered in an audit.

• **Evidence is the deliverable auditors want.** A score is only defensible if each improvement action carries **who owns it, its implementation status, its test status/date, and the proof**. Compliance Manager centralizes that record; this solution makes producing it a routine, not a fire drill.

• **Control mapping avoids duplicated effort.** One well-implemented control (say, unified audit logging) can satisfy requirements across NIST, ISO, HIPAA, and your internal baseline at once. Compliance Manager's **shared/control mapping** shows that leverage so you fix once and score many.

• **Regulatory applicability is not a technical call.** *Which* regulations apply, *which* controls are in scope, and *whether* the evidence satisfies the obligation are **compliance/records/privacy/legal determinations**. This solution provides the configuration method and the evidence; it does not decide applicability or sign off on adequacy.

How it works

1. **Baseline the score (Assess).** The default **Data Protection Baseline** assessment is present for all Microsoft 365 tenants; capture the current **Compliance Score**, the improvement actions, and the role/licensing readiness as the starting point (`CM Roles – Separation Evidence`).

1. **Design the assessments and scope (Design).** With compliance stakeholders, decide which **assessment templates** are in scope (the included baseline plus any **premium templates** — NIST 800-53, ISO 27001, HIPAA/HITECH, GDPR, etc. — that your licensing entitles), how assessments are **grouped**, and who **owns** each area. Regulatory applicability is the stakeholders' call.

1. **Populate roles with separation (Configure — guardrails).** The Compliance Manager role groups are assigned least-privilege so the people who *administer* Compliance Manager are separated from those who *contribute* action updates and those who only *read* — the auditable access record.

1. **Create the assessments and the action plan (Configure).** Create the in-scope assessments from their templates in the portal, then build the **improvement-action plan** (`CM Action Plan – Pilot`): each action assigned an **owner**, a **target date**, an **implementation status**, and a **test status**, with **evidence** attached.

1. **Turn on automatic testing where it applies (Configure).** Compliance Manager can **automatically test** certain improvement actions by reading signals from your Microsoft 365 configuration (continuous monitoring) — enable it so technical actions update their status without manual re-checks (`CM Automatic Testing – Setting`). Availability is plan/action-dependent; verify.

1. **Validate the evidence (Pilot → Validate).** Confirm the **technical state** behind the actions (audit enabled, DLP/retention/label/CA present, etc.) matches what the assessment claims, attach the evidence, and set test status/date — piloting any *technical* remediation in simulation/test first.

1. **Report and expand (Validate → Expand).** Roll up the score posture, evidence register, and role

separation (`CM Score Posture – Report`); then add the remaining assessments and stand up the **maintenance cadence** (re-test, re-evidence, review owners, watch template/regulation updates).

The four building blocks (what Compliance Manager gives you)

- **Assessments** — a grouping of controls from a **template** (a regulation, standard, or policy).

The **Data Protection Baseline** is included; **premium templates** are licensing-gated, and you can build **custom templates** to add your own or non-Microsoft controls.

- **Improvement actions** — the recommended steps that raise the score. Each has **points**,

implementation status (Not implemented / Implemented / Alternative / Planned / Out of scope), **test status** (Not assessed / Passed / Failed…), an **owner**, and **evidence**. Actions are **customer-managed** (yours) or **Microsoft-managed** (Microsoft's shared responsibility).

- **Controls & control mapping** — a control is a requirement of a regulation/standard; the **same**

control (and the action that satisfies it) can appear across **many** assessments, so one fix scores in several places (shared / control mapping).

- **Evidence & the score** — points accrue as actions are implemented and tested; **evidence**

(documents, test results, owner, date) attached to each action is the defensible audit trail. The **authoritative score and export** live in the Compliance Manager area of the portal.

The role-separation model (least privilege)

Role group	Who	Can (typical)
Compliance Manager Administrators	Program owners / IT config	Read and edit all Compliance Manager data; manage settings, templates, and role assignment
Compliance Manager Assessors	Assessment leads	Read data, **create assessments**, implement improvement actions, and edit **test** status
Compliance Manager Contributors	Action owners	Read data, create assessments, and **edit improvement actions** (not test status)
Compliance Manager Readers	Oversight / auditors	**Read-only** access to Compliance Manager data

> *Global Administrator, Compliance Administrator, and Compliance Data Administrator also have access. **Verify the exact role/role-group names and rights in your tenant** — Purview role naming and Compliance Manager permissions evolve; do not assume. Least privilege is the point: assessors and contributors should not need administrator rights, and readers/auditors get read-only.*

What you can control

- The **assessment templates** in scope (the included baseline plus licensed premium/custom templates)

and how assessments are **grouped**.

• The **improvement-action plan** — owners, target dates, implementation status, test status, and the **evidence** attached to each action.

• Whether **automatic testing** of eligible actions is on, so technical actions self-update.

• The **role-group membership** that enforces least-privilege separation.

• The **pilot subset** (a single baseline assessment) validated first before the full set is built.

Limitations (be honest with buyers)

• **It measures, it doesn't enforce.** Compliance Manager scores and recommends; it does **not** change your tenant. Acting on an improvement action is a **separate** configuration change (piloted in simulation/test where high-impact) owned by that feature's solution.

• **Premium content is licensing-gated.** The **Data Protection Baseline** is included; **premium assessment templates **(NIST, ISO, HIPAA, GDPR, etc.) require** Microsoft 365 E5 / E5 Compliance **or the** Compliance Manager Premium Assessment Add-On**, and the** number **of premium assessments available depends on your licensing/seat count.** Verify entitlement — do not assume a template is available.**

• **Portal-driven.** Assessments, improvement actions, evidence upload, and the authoritative score are managed in the **Purview portal**. Compliance Manager does **not** expose a broad public PowerShell/Graph API to create assessments or set action status programmatically; the provided scripts assess **readiness, roles, and the technical evidence** behind actions and structure the action/evidence plan — they do not replace the portal.

• **Automatic testing is partial.** Only **eligible** improvement actions auto-test from Microsoft 365 signals; others require manual implementation/test and uploaded evidence. Availability is plan/action-dependent — verify.

• **Applicability and adequacy are not technical.** *Which* regulations apply and *whether* evidence satisfies them are **compliance/records/privacy/legal** determinations, not outputs of this tool.

• **No secrets in automation.** The provided scripts use interactive modern-auth sign-in; they never embed credentials.

Naming convention (used in every doc and script)

Every artifact this solution creates or tracks is named `<Purpose> – <Scope> – <Stage>` and reused verbatim across the docs, scripts, and portal. The standard set:

Artifact	Name
Baseline assessment (pilot)	`CM Assessment – Baseline – Pilot`
Production assessment (per regulation)	`CM Assessment – <Regulation> – Production`
Improvement-action plan (pilot)	`CM Action Plan – Pilot`

Artifact	Name
Evidence register	`CM Evidence – Register`
Automatic-testing setting	`CM Automatic Testing – Setting`
Score posture report	`CM Score Posture – Report`
Role-separation evidence snapshot	`CM Roles – Separation Evidence`
Assessment scope / owners record	`CM Scope – Record`

The standard deployment model

> *Baseline the score → design the in-scope assessments, grouping, and owners → configure roles (separation), create assessments, build the action plan, enable automatic testing → validate the evidence behind the actions (piloting any technical remediation in simulation/test) → report the posture → expand to the full assessment set and run the maintenance cadence. Pattern:* ***Assess*** *→* ***Design*** *→* ***Configure*** *→* ***Pilot (simulate/test)*** *→* ***Validate*** *→* ***Expand*** *— regulatory applicability and adequacy deferred to compliance/records/privacy/legal at every step.*

2. Requirements Guide — Microsoft Purview Compliance Manager Implementation

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites (tenant licensing, Purview roles, the PowerShell/Graph toolchain, in-scope data sources, compliance/privacy/legal stakeholders, and a pilot scope with change control) are in `global-requirements-purview.md` — this guide adds the Compliance-Manager-specific detail. **Licensing, template availability, and portal paths are plan-dependent and the portal evolves — verify each against your own licensing and tenant.**

2.1 Licensing — base Compliance Manager and premium/custom templates

Description: Compliance Manager and the **Data Protection Baseline** assessment are available to all Microsoft 365 / Office 365 commercial subscriptions. **Premium assessment templates** (NIST 800-53, ISO 27001, HIPAA/HITECH, GDPR, and hundreds more) and **custom templates** require **Microsoft 365 E5 / E5 Compliance** or the **Compliance Manager Premium Assessment Add-On**; the **number** of premium assessments you can create is a function of your licensing / seat entitlement. (GCC/GCC High and other sovereign clouds may differ.) **Why:** The baseline is free but every regulation-specific template is entitlement-gated; a template you plan to assess against may not be available on your plan — the most common blocker. **Verify:** Microsoft 365 admin center → `Billing` → `Licenses` for the E5 / E5 Compliance / add-on entitlement; in the Purview portal → **Compliance Manager** → **Assessment templates**, confirm the templates you need show as **available to create**. `CMPMGR-Discovery.ps1` reports the licensing SKUs it can read via Graph. **Confirm exact entitlement with Microsoft licensing — do not assume. Implement:** Assign/purchase the required E5 / E5 Compliance / Premium Assessment Add-On before relying on a premium or custom template.

2.2 Compliance Manager role groups populated with least-privilege separation

Description: The Compliance-Manager-specific role groups — **Compliance Manager Administrators**, **Compliance Manager Assessors**, **Compliance Manager Contributors**, and **Compliance Manager Readers** — populated so administrators are separated from action **contributors** and from read-only **readers/auditors**. (Global Administrator, Compliance Administrator, and Compliance Data Administrator also grant access.) **Why:** Least-privilege separation is the auditable access control: assessors/contributors update actions and evidence without administrator rights, and oversight/auditors get read-only. The evidence you produce is only defensible if access to it was governed. **Verify:** Purview portal → `Settings` → `Roles & scopes` → `Permissions` (or, via `Connect-IPPSSession`, `Get-RoleGroupMember 'Compliance Manager Contributors'` etc.) shows the intended, separated membership. `CMPMGR-Discovery.ps1` prints each group's membership as the `CM Roles – Separation Evidence` snapshot and flags administrators who are also contributors. **Verify the exact role-group names in your tenant — Purview role naming evolves. Implement:** Assign membership under change control with `CMPMGR-Set-Scope.ps1` (`-WhatIf` first, then `-Commit`); grant the **minimum** role each person needs and keep readers/auditors read-only.

2.3 Named compliance, records, privacy & legal owners (applicability + adequacy)

Description: Named owners in **compliance, records-management, privacy, and legal** who decide **which regulations/standards apply**, which controls are **in scope** or **out of scope**, and whether the collected **evidence satisfies** the obligation — plus a **business owner** for each in-scope assessment. **Why:** Regulatory applicability and evidence adequacy are **not** technical determinations. The score and evidence are inputs to a compliance decision; the decision itself belongs to these functions. **Verify:** The in-scope regulations/standards, the scoped/out-of-scope controls, and the named approvers are recorded (`CM Scope – Record`). **Implement:** Engage the governance functions, capture the applicable frameworks and the scope decisions, and assign an owner per assessment before building the action plan.

2.4 In-scope assessment templates and grouping decided

Description: The **set of assessment templates** to stand up — starting with the **Data Protection Baseline** and adding the licensed **premium** (and any **custom**) templates your obligations require — and how assessments are **grouped** (e.g. by regulation, business unit, or environment) so control mapping and reporting are coherent. **Why:** Assessments are the unit of scoring; picking the right templates and grouping is what makes the score meaningful and lets shared controls map across frameworks. **Verify:** The template list and grouping are agreed with the governance owners; each chosen template shows as available (Requirement 2.1). **Implement:** Confirm each template's availability and create a grouping plan before creating assessments; where a needed framework has no template, plan a **custom template**.

2.5 Improvement-action owners and evidence sources identified

Description: For the pilot assessment, the **owner** of each improvement action, the **target date**, and where the **evidence** will come from — including which actions are candidates for **automatic testing** (auto-updated from Microsoft 365 signals) versus **manual** evidence upload. **Why:** A score with no owners and no evidence is not defensible. Ownership and evidence source are what turn recommendations into a

trackable, auditable plan (`CM Action Plan – Pilot`, `CM Evidence – Register`). **Verify:** Each pilot action has an owner, a target date, and a named evidence source; automatic-vs- manual actions are identified. **Implement:** Build the action plan with `CMPMGR-Configuration.ps1` (`-WhatIf` first) from the owner-provided list; capture the evidence source per action.

2.6 Automatic-testing decision and the underlying technical signals

Description: A decision on whether to enable **automatic testing** of eligible improvement actions (continuous monitoring reads your Microsoft 365 configuration to update an action's status), and awareness that automatic testing depends on the **underlying technical controls** (e.g. unified audit logging, DLP/retention/sensitivity-label policies, Conditional Access/MFA) actually being present. **Why:** Automatic testing keeps technical actions current without manual re-checks — but only for **eligible** actions, and only when the underlying signal exists. Knowing which is which prevents a false sense of coverage. **Verify:** Purview portal → **Compliance Manager** → **Settings** for the automatic-testing option (`CM Automatic Testing – Setting`); `CMPMGR-Validation.ps1` reports the state of the common technical signals (audit, DLP, retention, labels, Conditional Access) that back automatable actions. **Implement:** Enable automatic testing where your governance owners agree; for actions it can't auto-test, plan manual evidence.

2.7 Security & Compliance PowerShell + Microsoft Graph toolchain

Description: A workstation with the **ExchangeOnlineManagement** module (providing `Connect-IPPSSession` for role-group and evidence cmdlets) and **Microsoft Graph PowerShell** (for licensing and Conditional Access/MFA evidence), used with a modern-auth / MFA-capable admin holding the appropriate Compliance Manager and read roles. **Why:** The five provided scripts assess readiness, roles, and technical evidence through Security & Compliance PowerShell and Graph. Compliance Manager itself is **portal-managed** — the scripts support it, they do not create assessments. **Verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed; `Get-RoleGroup` returns the Compliance Manager groups. `CMPMGR-Discovery.ps1` performs these checks. **Implement:** `Install-Module ExchangeOnlineManagement`; `Install-Module Microsoft.Graph`; sign in with the role-holding admin and grant the read scopes the scripts request.

2.8 A pilot assessment and change control

Description: A named **pilot assessment** (`CM Assessment – Baseline – Pilot`, typically the Data Protection Baseline) validated first — its action plan, evidence, and automatic-testing behaviour — before the full set of production assessments is built, plus a **change-control** path for any technical remediation an action triggers (consistent with `global-requirements-purview.md` §6). **Why:** Standing up every framework at once produces an unmanageable action backlog; validating one assessment end-to-end proves the ownership, evidence, and testing model before scaling. Technical remediations are high-impact and are piloted in simulation/test under change control. **Verify:** A named pilot assessment and its owner exist; a change window/approval path for technical remediation is defined. **Implement:** Choose the baseline as the pilot, validate it end-to-end, then expand; agree change control before acting on any high-impact improvement action.

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

• **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.

• **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.

• **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

• **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

- **Why required:** Configuration, automation, and the provided scripts run through these.
- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams, endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.
- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with stakeholders.
- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal** stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).
- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements, not technical defaults; several capabilities have HR/legal sensitivity.
- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

- **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.
- **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate → Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.
- **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change window/approval path.
- **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Microsoft Purview Compliance Manager Implementation

Follow these steps **in order**. Configuration is done in the **Microsoft Purview portal** (`https://purview.microsoft.com` → **Compliance Manager**) and, where automated, via **Security & Compliance PowerShell** (`Connect-IPPSSession`, for role groups and technical evidence) and **Microsoft Graph** (for licensing and Conditional Access/MFA evidence). Artifact names follow the `<Purpose> – <Scope> – <Stage>` convention from the Overview and are reused verbatim. **Portal paths, template availability, and cmdlets are plan-dependent and the portal evolves — verify against your tenant.**

> ***Model:** Baseline the score, design the assessments/scope/owners, configure roles + assessments + the action plan + automatic testing, validate the evidence behind the actions, report, then expand. Pattern: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand.** **Compliance Manager measures — it does not enforce.** Any *technical* remediation an improvement action recommends is a **separate, piloted change** owned by that feature's solution; and **regulatory applicability and evidence adequacy are compliance/records/privacy/legal determinations**, not decisions this guide makes.*

Step 1 — Baseline the score and capture the role/licensing readiness (Assess)

1. Confirm licensing (Requirement 2.1): in the portal → **Compliance Manager** → **Assessment templates**,

the templates you need show as available. **Verify entitlement with Microsoft licensing — do not assume.**

1. Run `CMPMGR-Discovery.ps1` (read-only). It reports the licensing SKUs it can read, the membership of

each Compliance Manager role group (the `CM Roles – Separation Evidence` snapshot), and flags any administrator who is also a contributor. Note the current **Compliance Score** and the **Data Protection Baseline** improvement actions from the portal dashboard as your starting point.

1. **Pass/fail gate:** licensing confirmed for the templates in scope, the Compliance Manager role

groups exist, and you have the baseline score recorded. **Do not proceed** until the governance owners (Requirement 2.3) have confirmed which frameworks apply and are in scope. Fail → resolve before configuring.

Step 2 — Assign roles with least-privilege separation (Configure — guardrails)

1. Portal → `Settings → Roles & scopes → Permissions`: populate the Compliance Manager role groups

(Requirement 2.2):

• **Compliance Manager Administrators** → the program owners / IT config staff.

• **Compliance Manager Assessors** → assessment leads who create assessments and set **test** status.

• **Compliance Manager Contributors** → the improvement-action **owners** who update actions/evidence.

• **Compliance Manager Readers** → oversight/auditors, **read-only**.

1. Or manage membership with `CMPMGR-Set-Scope.ps1` — it composes `Add-RoleGroupMember` / `Remove-RoleGroupMember`. **It runs with** `-WhatIf` **by default** and prints exactly what it would change; add `-Commit` to apply. Grant the **minimum** role each person needs.

1. **Pass/fail gate:** each person holds the least-privilege role; administrators are separated from

contributors; readers/auditors are read-only. Re-run `CMPMGR-Discovery.ps1` and confirm the `CM Roles – Separation Evidence` snapshot. **Rollback:** remove any over-granted membership with `CMPMGR-Set-Scope.ps1 -Commit`.

Step 3 — Design the in-scope assessments, grouping, and owners (Design)

1. With the governance owners, confirm the **in-scope assessment templates** (Requirement 2.4): the

Data Protection Baseline plus the licensed **premium**/**custom** templates your obligations require. **Applicability is the owners' determination**, not a technical default.

1. Decide the **grouping** (by regulation / business unit / environment) so control mapping and

reporting are coherent, and assign a **business owner** per assessment.

1. Record the design as `CM Scope – Record` (templates, grouping, owners, in-/out-of-scope controls).

Step 4 — Create the pilot assessment (Configure — pilot-first)

1. Portal → **Compliance Manager** → **Assessments** → **Add assessment**: create

`CM Assessment – Baseline – Pilot` from the **Data Protection Baseline** template, in the agreed group. (Premium/custom templates require the entitlement from Requirement 2.1.)

1. **Keep the pilot to one assessment.** Validating the baseline end-to-end — ownership, evidence,

automatic testing — proves the model before you create the full framework set. Compliance Manager does not change your tenant, so creating the assessment is safe; the *work* it surfaces is what you pilot.

1. **Pass/fail gate:** the pilot assessment exists in the correct group with an owner, and its

improvement actions and current score are visible. Fail → check template availability/licensing. **Rollback:** an assessment can be removed in the portal without affecting tenant configuration.

Step 5 — Build the improvement-action plan and evidence register (Configure)

1. For `CM Assessment – Baseline – Pilot`, assign each **improvement action** an **owner**, a **target

date**, and an** implementation status**, in the portal (action** → Assign** / edit).

1. Use `CMPMGR-Configuration.ps1` to build the tracking artifacts from the owner-provided list — it

validates the action plan and, with `-Commit`, writes the local `CM Action Plan – Pilot` and `CM Evidence – Register` files (owner, target date, status, evidence source per action). **It runs with `-WhatIf` by default** and only *describes* the plan; **it makes no tenant changes** — Compliance Manager has no write API, so assignments and evidence upload happen in the portal, driven by these artifacts.

1. Attach **evidence** to each action in the portal (documents, test results) and record its source in

the register.

1. **Pass/fail gate:** every pilot action has an owner, a target date, a status, and a named evidence

source. Fail → complete the plan before validating.

Step 6 — Enable automatic testing where it applies (Configure)

1. Portal → **Compliance Manager** → **Settings**: set the **automatic testing** option

(`CM Automatic Testing – Setting`) per the governance owners' decision (Requirement 2.6). Eligible improvement actions will update their **test status** from your Microsoft 365 configuration signals.

1. Run `CMPMGR-Validation.ps1` (read-only) to confirm the **underlying technical signals** the

automatable actions depend on are present — e.g. **unified audit logging enabled**, **DLP / retention / sensitivity-label** policies present, **Conditional Access / MFA** configured. This tells you which actions can auto-pass and which still need **manual** evidence.

1. **Pass/fail gate:** automatic testing is set as agreed, and you know which actions are auto-tested

vs manual-evidence. Fail → enable automatic testing or record the manual-evidence actions.

Step 7 — Validate the evidence behind the actions (Pilot → Validate)

1. Run the Testing Guide (`05-testing.md`). Confirm: the pilot assessment shows a score; each action's

implementation and **test** status is set with **evidence**; automatic-tested actions reflect the real technical state (cross-checked by `CMPMGR-Validation.ps1`); role separation holds.

1. Where an action recommends a **technical change** (enable audit, add a DLP/retention/label policy,

tighten Conditional Access), **pilot that change in simulation/test first** under its own change control — those high-impact changes are owned by their feature's solution, not switched on blind here. Re-run `CMPMGR-Validation.ps1` to capture the new evidence.

1. Run `CMPMGR-Report.ps1` for the `CM Score Posture – Report` (score, action status rollup, evidence

register, role separation, licensing).

1. **Pass/fail gate:** the pilot assessment is fully owned, evidenced, and tested; automatic testing

reflects reality; the posture report is accurate. Fail → complete evidence/testing and re-validate.

Step 8 — Expand to the full assessment set and run the cadence (Expand)

1. With the governance owners, create the remaining production assessments —

`CM Assessment – <Regulation> – Production` — from their licensed templates, in the agreed grouping. **Lean on control mapping:** actions already implemented for the baseline often satisfy controls in the new assessments automatically (shared controls), so the incremental effort is the *gap*.

1. Extend the **action plan** and **evidence register** to the new assessments (owners, dates,

evidence) with `CMPMGR-Configuration.ps1`.

1. Stand up the **maintenance cadence**: periodic re-test/re-evidence of actions, review of owners

(joiners/leavers), watch for **template/regulation updates** Microsoft publishes, and re-run `CMPMGR-Report.ps1` on a schedule for the posture trend.

1. **Pass/fail gate:** the full in-scope set exists, is owned and evidenced, automatic testing is

running, and a recurring review is scheduled. **Rollback:** any assessment can be removed in the portal without touching tenant configuration; scope can be narrowed at any time.

What this guide does NOT decide

• **Which regulations/standards apply and whether the evidence satisfies them** — a

compliance/records/privacy/legal determination. This guide configures the assessments, the action plan, and the evidence, and produces the score and posture; adequacy and sign-off belong to those functions.

• **The high-impact technical changes an action recommends** — enabling audit, DLP, retention, labels,

Conditional Access, etc. are **separate, piloted-in-simulation** changes owned by their own solution; Compliance Manager only measures whether they are in place.

5. Testing Guide — Microsoft Purview Compliance Manager Implementation

Run these after assigning roles (Step 2) and building the pilot assessment, action plan, and automatic testing (Steps 4–6), and again after each change and before expanding. Every test here is **safe and read-only** or contained to the **pilot assessment** — Compliance Manager itself changes nothing on the tenant; the point is to prove the **score, ownership, evidence, automatic testing, and role separation** all work before you build the full framework set. **Adequacy and applicability remain a compliance/legal determination — these tests validate the mechanism.**

Test 1 — Role separation is in place (the access guardrail)

Do: Run `CMPMGR-Discovery.ps1`; review the `CM Roles – Separation Evidence` snapshot of each Compliance Manager role group's membership. **Expected:** Administrators are separated from contributors; assessors set test status; readers/ auditors are **read-only**. No administrator is silently also a contributor unless the governance owners accepted it. **Fail** → correct membership with `CMPMGR-Set-Scope.ps1` (Implementation Step 2) before proceeding.

Test 2 — Licensing supports the in-scope templates

Do: Run `CMPMGR-Discovery.ps1` and, in the portal → **Compliance Manager** → **Assessment templates**, confirm each in-scope template is available to create. **Expected:** The **Data Protection Baseline** is present, and each **premium/custom** template you plan to use shows as available under your entitlement. **Fail** → resolve licensing (Requirement 2.1) before creating that assessment.

Test 3 — The pilot assessment exists and is scored

Do: In the portal → **Compliance Manager** → **Assessments**, open `CM Assessment – Baseline – Pilot`. **Expected:** The assessment is in the agreed group, has an owner, and shows a **Compliance Score** and its improvement actions. **Fail** → recreate/repair the assessment (Implementation Step 4).

Test 4 — Every pilot action has an owner, target date, status, and evidence source

Do: Run `CMPMGR-Report.ps1`; review the `CM Action Plan – Pilot` / `CM Evidence – Register` rollup against the assessment's actions in the portal. **Expected:** Each improvement action has an **owner**, a **target date**, an **implementation status**, and a **named evidence source**; nothing is unassigned. **Fail** → complete the plan with `CMPMGR-Configuration.ps1` and assign in the portal.

Test 5 — Automatic testing reflects the real technical state (true evidence)

Do: Confirm automatic testing is enabled (`CM Automatic Testing – Setting`), then run `CMPMGR-Validation.ps1` (read-only) and compare its findings to the auto-tested actions' status. **Expected:** For an action Compliance Manager auto-tests (e.g. **unified audit logging enabled**), the tool's finding matches the action's **test status** — the score reflects reality, not a stale value. **Fail** → confirm auto-testing eligibility and the underlying signal; some actions need manual evidence.

Test 6 — A not-yet-implemented control scores as such (no false pass)

Do: Pick an improvement action whose technical control is **not** in place; check its status in the portal and cross-check with `CMPMGR-Validation.ps1`. **Expected:** The action shows **Not implemented / not tested** (or Failed), and the tool confirms the control is absent — the score is **not** inflated. **Fail** → correct the status/evidence; do not mark implemented without proof.

Test 7 — Manual evidence is attached and defensible

Do: Open two or three manually-evidenced actions in the portal; confirm the uploaded **evidence**, **owner**, and **test date** are present, and that `CM Evidence – Register` records the source. **Expected:** Each manual action carries proof, an owner, and a date — an auditor-ready record. **Fail** → attach the evidence and record it in the register.

Test 8 — Control mapping / shared controls behave as expected

Do: After the baseline actions are implemented, create a second assessment from a licensed template (a pilot of expansion) and inspect the shared/mapped controls. **Expected:** Controls already satisfied by baseline actions show as **implemented** in the new assessment via **shared/control mapping** — you did not have to redo the work. **Fail** → verify the action is a shared/Microsoft-managed control and its status is set.

Test 9 — Posture report is accurate and complete

Do: Run `CMPMGR-Report.ps1` for the `CM Score Posture – Report`. **Expected:** The report rolls up the score, the action-status breakdown, the evidence register, the role-separation snapshot, and the licensing — matching the portal. It notes that the **authoritative score and export** are the portal's Compliance Manager export. **Fail** → confirm inputs and re-run.

Test 10 — Safe automation defaults

Do: Run `CMPMGR-Configuration.ps1` and `CMPMGR-Set-Scope.ps1` with no action switch. **Expected:** Each runs in `-WhatIf` mode and only *describes* the change; nothing is written until `-Commit` is supplied. `CMPMGR-Discovery.ps1`, `CMPMGR-Validation.ps1`, and `CMPMGR-Report.ps1` are read-only. **Fail** → stop; do not run with `-Commit` until the dry-run output is correct.

Gate to expand: Tests 1–2 (guardrails + licensing), 3–4 (assessment + ownership), 5–7 (evidence accuracy), 8 (control mapping), and 9–10 (reporting + safety) all pass for the pilot → proceed to the full assessment set (Implementation Step 8). Any fail → correct and re-test. **Whether the resulting score/evidence satisfies an obligation is a compliance/legal decision, not a technical one.**

6. Troubleshooting Guide — Microsoft Purview Compliance Manager Implementation

Field issues and how to resolve them. **Symptom** → **Likely cause** → **Resolution.** Confirm the basics first: correct licensing, the right Compliance Manager role, and a successful `Connect-IPPSSession` / `Connect-MgGraph`. Portal paths, template availability, and cmdlets are plan-dependent and evolve — **verify against your tenant.**

Compliance Manager isn't visible, or a template can't be created

Likely cause: The admin lacks a Compliance Manager role, or the template is a **premium/custom** one your plan doesn't entitle. **Resolution:** Ensure your account is in a Compliance Manager role group (Requirement 2.2). The **Data Protection Baseline** is available to all tenants; **premium** templates require **E5 / E5 Compliance / Premium Assessment Add-On** and the **count** is seat-dependent (Requirement

2.1). Confirm entitlement in the M365 admin center — **verify with Microsoft licensing, don't assume**. `CMPMGR-Discovery.ps1` reports the SKUs it can read.

A Compliance Manager role group is missing (`Get-RoleGroup` returns nothing)

Likely cause: The exact role-group name differs in your tenant, or the group isn't provisioned. **Resolution:** Purview role naming evolves — verify the exact names in `Settings → Roles & scopes → Permissions`. Compliance Administrator / Compliance Data Administrator / Global Administrator also grant access. Adjust the name you pass to `CMPMGR-Set-Scope.ps1` to match your tenant.

The same person is both an Administrator and a Contributor (separation note)

Likely cause: One identity added to **Compliance Manager Administrators** *and* **Contributors**. **Resolution:** Grant the **minimum** role each person needs — administrators don't also need the contributor role. Remove the overlap with `CMPMGR-Set-Scope.ps1` (`-WhatIf` then `-Commit`), or record governance acceptance for a stated reason. `CMPMGR-Discovery.ps1` flags the overlap.

`CMPMGR-Configuration.ps1` didn't write any files

Likely cause: It ran in the default `-WhatIf` mode (by design). **Resolution:** Review the plan it printed; re-run with `-Commit` (and `-OutDir`) to write `CM-Action-Plan-Pilot.csv` / `CM-Evidence-Register.csv`. Remember this tool makes **no tenant changes** — assignments and evidence upload are done in the Purview portal from these artifacts.

`CMPMGR-Configuration.ps1` reports validation issues

Likely cause: The input CSV has blank owners/dates, an unrecognized status value, or a missing evidence source. **Resolution:** Fix the flagged rows. `ImplementationStatus` must be one of *Not implemented / Implemented / Alternative implementation / Planned / Out of scope*; `TestStatus` one of *Not assessed / Passed / Failed - low|medium|high risk*; every action needs an **owner**, a valid **TargetDate**, and an **EvidenceSource** (Requirement 2.5).

The Compliance Score looks wrong or hasn't moved after implementing a control

Likely cause: The improvement action's status wasn't updated, automatic testing isn't enabled/eligible for it, or the control was implemented in a way the signal doesn't detect. **Resolution:** Confirm the action's **implementation** and **test** status in the portal; enable **automatic testing** (`CM Automatic Testing – Setting`, Requirement 2.6) for eligible actions; for others, set the status manually with evidence. Cross-check the underlying control with `CMPMGR-Validation.ps1`. Score updates for automatic tests can take time to propagate.

An action shows "Implemented" but the control isn't actually there (false pass)

Likely cause: The status was set manually without proof, or a stale automatic result. **Resolution:** Run `CMPMGR-Validation.ps1` — if it reports the control **Absent**, correct the action's status; never mark implemented without evidence. This is exactly the cross-check the validator exists for.

`CMPMGR-Validation.ps1` reports a control "Absent" that you believe is configured

Likely cause: The admin lacks read rights to that area, the Graph scope wasn't granted, or the control is configured in a place the check doesn't read (e.g. security defaults vs Conditional Access). **Resolution:** Ensure the account can read DLP/retention/labels (S&C PowerShell) and that `Connect-MgGraph -Scopes Policy.Read.All` succeeded for Conditional Access. The tool checks common signals; some controls have alternative implementations — record those as **manual** evidence.

`Get-Label` / `Get-DlpCompliancePolicy` / `Get-RetentionCompliancePolicy` not recognised

Likely cause: Not connected via `Connect-IPPSSession`, or an outdated ExchangeOnlineManagement module. **Resolution:** `Import-Module ExchangeOnlineManagement`; `Update-Module ExchangeOnlineManagement`; `Connect-IPPSSession` (Security & Compliance PowerShell — **not** `Connect-ExchangeOnline`).

Automatic testing isn't updating any actions

Likely cause: Automatic testing is off, the actions aren't eligible for it, or the underlying signal is absent. **Resolution:** Enable automatic testing in **Compliance Manager** → **Settings**; note that only **eligible** actions auto-test (Requirement 2.6). For ineligible actions, plan manual evidence. Verify the underlying control exists with `CMPMGR-Validation.ps1`.

Shared control implemented once, but a second assessment still shows it not done

Likely cause: The action is customer-managed and set on one assessment only, or the control isn't a shared/mapped control across those templates. **Resolution:** Confirm the action is a **shared** (or Microsoft-managed) control; for shared controls, updating it in one place should reflect across mapped assessments. If it's not mapped, it must be implemented per assessment. Control mapping is a template property — verify in the portal.

`CMPMGR-Set-Scope.ps1 -Commit` fails to add/remove a member

Likely cause: The signed-in admin can't manage role-group membership, the member identity is wrong, or the role-group name doesn't match your tenant. **Resolution:** Use an admin permitted to manage role groups; pass the member's exact UPN/primary SMTP; confirm the role-group name (`Get-RoleGroup`). Re-run `-WhatIf` to preview before `-Commit`.

"Does this evidence satisfy the regulation? Are we compliant?"

Not a tool question. Compliance Manager produces the **score and evidence**; **whether a regulation applies and whether the evidence satisfies it is a compliance/records/privacy/legal determination.** Route the posture and evidence (`CM Score Posture – Report`, `CM Evidence – Register`) to those functions for the adequacy decision — the tool provides method and proof, not the verdict.

7. Best Practices — Microsoft Purview Compliance Manager Implementation

- **Baseline first, then expand.** Capture the current **Compliance Score** and validate the included

Data Protection Baseline assessment end-to-end before creating a stack of framework-specific assessments. One assessment owned and evidenced properly beats ten assessments with unassigned actions and no proof.

- **Assign an owner and a date to every improvement action.** A score with unowned, undated actions is

not a plan. Ownership and target dates in `CM Action Plan – Pilot` are what turn recommendations into trackable, auditable work.

- **Evidence is the deliverable.** Attach documentation, test results, an owner, and a test date to

each action. The number is only defensible with the proof behind it — `CM Evidence – Register` is the auditor-ready record.

- **Lean on control mapping.** Implement a shared control once and let it score across every assessment

that references it (baseline + NIST + ISO + HIPAA…). Prioritize **high-point, widely-mapped** actions for the most score per unit of effort, and only do the *gap* when adding a new framework.

- **Enable automatic testing — but know its limits.** Turn on automatic testing so eligible technical

actions self-update from Microsoft 365 signals; but confirm with `CMPMGR-Validation.ps1` that the **underlying control actually exists**, and plan **manual evidence** for actions that can't auto-test. Automatic testing is not full coverage.

- **Never mark an action implemented without proof.** A false "implemented" inflates the score and

fails the first audit. If the technical control isn't in place, the action stays Not implemented — `CMPMGR-Validation.ps1` is your cross-check against wishful status.

- **Compliance Manager measures; it does not enforce.** Acting on an improvement action — enabling

audit, DLP, retention, labels, Conditional Access — is a **separate, high-impact change** owned by that feature's solution and **piloted in simulation/test first**. Don't switch controls on tenant-wide from the score dashboard.

- **Least privilege and separation.** Keep **Administrators** separate from **Contributors**, and keep

Readers/auditors read-only. Manage membership with `CMPMGR-Set-Scope.ps1` (`-WhatIf` then `-Commit`) and re-snapshot with `CMPMGR-Discovery.ps1` — membership drifts as people join and leave.

• **Always dry-run automation.** `CMPMGR-Configuration.ps1` and `CMPMGR-Set-Scope.ps1` default to

`-WhatIf`. Read every line of the planned change; run `-Commit` only after the output is right. The discovery, validation, and report scripts are read-only.

• **Applicability and adequacy belong to compliance/legal.** *Which* regulations apply, *which*

controls are in/out of scope, and *whether* the evidence satisfies the obligation are **compliance, records, privacy, and legal** determinations. The tool provides method, score, and evidence — not the verdict.

• **Watch for template and regulation updates.** Microsoft updates assessment templates as regulations

change; a template update can add controls and move your score. Review updates on a cadence and re-baseline affected assessments.

• **Group assessments deliberately.** Group by regulation, business unit, or environment so control

mapping and reporting stay coherent and the score is meaningful per audience.

• **Verify licensing and template availability against your tenant.** The baseline is included; premium

and custom templates are entitlement-gated and the count is seat-dependent; GCC/GCC High may differ. Confirm — never assume a template is available.

• **The portal is authoritative.** Assessments, evidence upload, and the official score/export live in

the Purview portal; the scripts assess readiness, roles, and technical evidence and structure the plan — they support the portal, they don't replace it.

8. Deliverables Summary — Microsoft Purview Compliance Manager Implementation

Documentation

Document	Purpose
Executive Summary	Business case, the measure-don't-enforce model, and what's in the box
1. Solution Overview	What Compliance Manager is, how it works, the four building blocks (assessments, improvement actions, control mapping, evidence), the role-separation model, limitations, and the naming convention
2. Requirements Guide	Every Compliance-Manager-specific prerequisite with Verify / Implement-if-missing (base + premium/custom licensing, role separation, governance owners, in-scope templates/grouping, action owners + evidence, automatic testing, toolchain, pilot)
Global Requirements (Purview)	Category-wide prerequisites, published once

Document	Purpose
3. Implementation Guide	Exact, ordered portal + PowerShell steps — baseline the score, roles-with-separation, create the pilot assessment, build the action plan + evidence register, enable automatic testing, validate, expand; applicability/adequacy deferred to compliance/legal
5. Testing Guide	Validation procedures with pass/fail gates (separation, licensing, assessment/ownership, evidence accuracy, control mapping, reporting, safe defaults)
6. Troubleshooting Guide	Field issues and remediation
7. Best Practices	Field-proven, evidence-first recommendations

PowerShell scripts

Script	Purpose	Default safety
`CMPMGR-Discovery.ps1`	Readiness + **role-separation** + licensing assessment; prints the `CM Roles – Separation Evidence` snapshot and the SKUs it can read	**Read-only**
`CMPMGR-Configuration.ps1`	Improvement-action **plan & evidence-register builder** — validates the owner-provided action list and writes the local `CM Action Plan – Pilot` / `CM Evidence – Register` (no tenant writes; Compliance Manager is portal-managed)	`-WhatIf` (needs `-Commit`)
`CMPMGR-Validation.ps1`	Collects the **technical evidence** behind automatable improvement actions — unified audit, DLP/retention/label presence, Conditional Access/MFA — and reports pass/absent per signal	**Read-only**
`CMPMGR-Report.ps1`	**Score posture rollup** — action-status breakdown, evidence register, role separation, and licensing; notes the authoritative score/export is the portal	**Read-only**
`CMPMGR-Set-Scope.ps1`	Role/health helper — manage Compliance Manager **role-group membership** for least-privilege separation	`-WhatIf` (needs `-Commit`)

All scripts run through **Security & Compliance PowerShell** (`Connect-IPPSSession`) and/or **Microsoft Graph** with interactive modern-auth; **no credentials or secrets are embedded**. `CMPMGR-Configuration.ps1` and `CMPMGR-Set-Scope.ps1` are **safe-by-default** (`-WhatIf`) and only make a change when `-Commit` is supplied. Compliance Manager itself is **portal-managed** — the scripts assess readiness, roles, and the technical evidence behind improvement actions and structure the action/evidence plan; they do not create assessments or set action status (there is no broad public write API for that).

Artifacts this solution creates (naming convention)

Artifact	Name
Baseline assessment (pilot)	`CM Assessment – Baseline – Pilot`
Production assessment (per regulation)	`CM Assessment – <Regulation> – Production`
Improvement-action plan (pilot)	`CM Action Plan – Pilot`
Evidence register	`CM Evidence – Register`
Automatic-testing setting	`CM Automatic Testing – Setting`
Score posture report	`CM Score Posture – Report`
Role-separation evidence snapshot	`CM Roles – Separation Evidence`
Assessment scope / owners record	`CM Scope – Record`

Outcome

Compliance turned into a **measured, evidenced score** in Microsoft Purview — assessments created, improvement actions owned and tested, control mapping leveraged, and evidence attached and defensible — with **automatic testing** keeping technical actions current and **least-privilege separation** enforced. The capability is in place, validated, and audit-ready, with **regulatory applicability and adequacy in the hands of compliance, records, privacy, and legal**.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

CMPMGR-Configuration.ps1

Purpose: Validates an owner-provided improvement-action list and produces the local tracking artifacts that drive the work in the Purview portal: the "CM Action Plan - Pilot" and the "CM Evidence - Register" (owner, target date, implementation status, test status, and evidence source per action). Compliance Manager is portal-managed and exposes no broad public write API, so this tool DOES NOT change the tenant — it structures the plan; assignment and evidence upload are performed in the portal from these artifacts. Safe by default: -WhatIf only describes; it writes the register files only when -Commit is supplied. HOW TO RUN Dry-run — describe the plan it would write (no files created): powershell -ExecutionPolicy Bypass -File .\CMPMGR-Configuration.ps1 -InputCsv .\actions.csv -WhatIf Apply — write the plan + evidence register locally: powershell -ExecutionPolicy Bypass -File .\CMPMGR-Configuration.ps1 -InputCsv .\actions.csv -OutDir .\out -Commit InputCsv columns (header row required): Action,Owner,TargetDate,ImplementationStatus,TestStatus,EvidenceSource,AutomaticTesting No tenant connection is required; this is a local planning tool. No credentials are stored. EXPECTED RESULTS -WhatIf: a validation summary and a preview of the rows that WOULD be written; no files. -Commit: writes CM-Action-Plan-Pilot.csv and CM-Evidence-Register.csv to -OutDir and prints a summary (counts by implementation/test status, actions missing an owner/date/evidence). .NOTES Purview — Microsoft Purview Compliance Manager Implementation. Local planning tool; makes NO tenant changes. Assignments and evidence upload happen in the Purview portal (Compliance Manager). > [CmdletBinding()] param([Parameter(Mandatory)][string]$InputCsv, [string]$OutDir = '.', [switch]$Commit, [switch]$WhatIf)

How to run: Dry-run — describe the plan it would write (no files created): powershell -ExecutionPolicy Bypass -File .\CMPMGR-Configuration.ps1 -InputCsv .\actions.csv -WhatIf Apply — write the plan + evidence register locally: powershell -ExecutionPolicy Bypass -File .\CMPMGR-Configuration.ps1 -InputCsv .\actions.csv -OutDir .\out -Commit InputCsv columns (header row required): Action,Owner,TargetDate,ImplementationStatus,TestStatus,EvidenceSource,AutomaticTesting No tenant connection is required; this is a local planning tool. No credentials are stored. EXPECTED RESULTS -WhatIf: a validation summary and a preview of the rows that WOULD be written; no files. -Commit: writes CM-Action-Plan-Pilot.csv and CM-Evidence-Register.csv to -OutDir and prints a summary (counts by implementation/test status, actions missing an owner/date/evidence). .NOTES Purview — Microsoft Purview Compliance Manager Implementation. Local planning tool; makes NO tenant changes. Assignments and evidence upload happen in the Purview portal (Compliance Manager). > [CmdletBinding()] param([Parameter(Mandatory)][string]$InputCsv, [string]$OutDir = '.', [switch]$Commit, [switch]$WhatIf)

CMPMGR-Discovery.ps1

Purpose: Assesses whether the tenant is ready to implement Microsoft Purview Compliance Manager and captures the role-separation baseline. Reports the membership of each Compliance Manager role group (Administrators / Assessors / Contributors / Readers) so administrators can be confirmed separate from contributors and readers, and reads the subscribed licensing SKUs (Graph) that gate premium assessment templates. Read-only — makes no changes. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPMGR-Discovery.ps1 powershell -ExecutionPolicy Bypass -File

.\CMPMGR-Discovery.ps1 -CsvPath C:\Temp\CM-Roles.csv Requires the ExchangeOnlineManagement module (Connect-IPPSSession, Security & Compliance PowerShell) and, for licensing, Microsoft.Graph (Connect-MgGraph). Sign in with an admin holding a Compliance Manager / compliance role. The score and assessments themselves are read from the Purview portal (Compliance Manager) — Compliance Manager has no broad public API. EXPECTED RESULTS A console summary: role-group membership (the "CM Roles - Separation Evidence" snapshot), a separation warning if an administrator is also a contributor, and the licensing SKUs relevant to premium templates. Optional CSV of the membership snapshot. .NOTES Purview — Microsoft Purview Compliance Manager Implementation. Read-only. No credentials are stored. Compliance Manager premium/custom templates are licensing-dependent (E5 / E5 Compliance / Premium Assessment Add-On) and the portal evolves — verify template availability against your own licensing and tenant. Verify the exact role-group names in your tenant; Purview role naming evolves. > [CmdletBinding()] param([string]$CsvPath)

How to run: powershell -ExecutionPolicy Bypass -File .\CMPMGR-Discovery.ps1 powershell -ExecutionPolicy Bypass -File .\CMPMGR-Discovery.ps1 -CsvPath C:\Temp\CM-Roles.csv Requires the ExchangeOnlineManagement module (Connect-IPPSSession, Security & Compliance PowerShell) and, for licensing, Microsoft.Graph (Connect-MgGraph). Sign in with an admin holding a Compliance Manager / compliance role. The score and assessments themselves are read from the Purview portal (Compliance Manager) — Compliance Manager has no broad public API. EXPECTED RESULTS A console summary: role-group membership (the "CM Roles - Separation Evidence" snapshot), a separation warning if an administrator is also a contributor, and the licensing SKUs relevant to premium templates. Optional CSV of the membership snapshot. .NOTES Purview — Microsoft Purview Compliance Manager Implementation. Read-only. No credentials are stored. Compliance Manager premium/custom templates are licensing-dependent (E5 / E5 Compliance / Premium Assessment Add-On) and the portal evolves — verify template availability against your own licensing and tenant. Verify the exact role-group names in your tenant; Purview role naming evolves. > [CmdletBinding()] param([string]$CsvPath)

CMPMGR-Report.ps1

Purpose: Produces the "CM Score Posture - Report": rolls up the local action plan / evidence register (from CMPMGR-Configuration.ps1), the role-separation snapshot (Compliance Manager role groups), and the licensing SKUs, into a single posture summary. It does NOT read the Compliance Manager score itself — that is portal-managed with no broad public API; the authoritative score and export are the Purview portal's Compliance Manager export. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPMGR-Report.ps1 -PlanCsv .\out\CM-Action-Plan-Pilot.csv powershell -ExecutionPolicy Bypass -File .\CMPMGR-Report.ps1 -PlanCsv .\out\CM-Action-Plan-Pilot.csv -HtmlPath .\CM-Posture.html PlanCsv is optional; without it, the report covers roles + licensing only. Requires ExchangeOnlineManagement (Connect-IPPSSession) for role membership and, optionally, Microsoft.Graph for licensing. EXPECTED RESULTS A console posture summary: action-status breakdown, actions missing owner/evidence, the role-separation snapshot, and the licensing SKUs — plus an optional standalone HTML report. .NOTES Purview — Microsoft Purview Compliance Manager Implementation. Read-only. No credentials are stored. Authoritative score/export = Purview portal (Compliance Manager). Verify against your tenant. > [CmdletBinding()] param([string]$PlanCsv, [string]$HtmlPath)

How to run: powershell -ExecutionPolicy Bypass -File .\CMPMGR-Report.ps1 -PlanCsv .\out\CM-Action-Plan-Pilot.csv powershell -ExecutionPolicy Bypass -File .\CMPMGR-Report.ps1 -PlanCsv .\out\CM-Action-Plan-Pilot.csv -HtmlPath .\CM-Posture.html PlanCsv is optional; without it, the report covers roles + licensing only. Requires ExchangeOnlineManagement (Connect-IPPSSession) for role membership and, optionally, Microsoft.Graph for licensing. EXPECTED RESULTS A console posture

summary: action-status breakdown, actions missing owner/evidence, the role-separation snapshot, and the licensing SKUs — plus an optional standalone HTML report. .NOTES Purview — Microsoft Purview Compliance Manager Implementation. Read-only. No credentials are stored. Authoritative score/export = Purview portal (Compliance Manager). Verify against your tenant. > [CmdletBinding()] param([string]$PlanCsv, [string]$HtmlPath)

CMPMGR-Set-Scope.ps1

Purpose: Adds or removes a member of a Compliance Manager role group (Administrators / Assessors / Contributors / Readers) to enforce least-privilege separation — administrators separate from contributors, readers/auditors read-only. Safe by default: -WhatIf only describes the change; it modifies membership only when -Commit is supplied. Uses the real Add-RoleGroupMember / Remove-RoleGroupMember cmdlets via Security & Compliance PowerShell. HOW TO RUN Dry-run (default) — describe what it WOULD change: powershell -ExecutionPolicy Bypass -File .\CMPMGR-Set-Scope.ps1 -RoleGroup 'Compliance Manager Contributors' -Member user@contoso.com -Action Add -WhatIf Apply: powershell -ExecutionPolicy Bypass -File .\CMPMGR-Set-Scope.ps1 -RoleGroup 'Compliance Manager Readers' -Member auditor@contoso.com -Action Add -Commit Requires ExchangeOnlineManagement (Connect-IPPSSession). Sign in with an admin who can manage role-group membership. Verify the exact role-group name in your tenant; Purview naming evolves. EXPECTED RESULTS -WhatIf: prints the current membership and the single add/remove it WOULD perform; no change. -Commit: performs the add/remove, then reprints the group's membership as confirmation. A post-change separation note warns if the member is now both an Administrator and a Contributor. .NOTES Purview — Microsoft Purview Compliance Manager Implementation. Safe-by-default (-WhatIf). No credentials are stored. Change membership under change control; grant the minimum role needed. > [CmdletBinding()] param([Parameter(Mandatory)][ValidateSet('Compliance Manager Administrators','Compliance Manager Assessors','Compliance Manager Contributors','Compliance Manager Readers')] [string]$RoleGroup, [Parameter(Mandatory)][string]$Member, [Parameter(Mandatory)][ValidateSet('Add','Remove')][string]$Action, [switch]$Commit, [switch]$WhatIf)

How to run: Dry-run (default) — describe what it WOULD change: powershell -ExecutionPolicy Bypass -File .\CMPMGR-Set-Scope.ps1 -RoleGroup 'Compliance Manager Contributors' -Member user@contoso.com -Action Add -WhatIf Apply: powershell -ExecutionPolicy Bypass -File .\CMPMGR-Set-Scope.ps1 -RoleGroup 'Compliance Manager Readers' -Member auditor@contoso.com -Action Add -Commit Requires ExchangeOnlineManagement (Connect-IPPSSession). Sign in with an admin who can manage role-group membership. Verify the exact role-group name in your tenant; Purview naming evolves. EXPECTED RESULTS -WhatIf: prints the current membership and the single add/remove it WOULD perform; no change. -Commit: performs the add/remove, then reprints the group's membership as confirmation. A post-change separation note warns if the member is now both an Administrator and a Contributor. .NOTES Purview — Microsoft Purview Compliance Manager Implementation. Safe-by-default (-WhatIf). No credentials are stored. Change membership under change control; grant the minimum role needed. > [CmdletBinding()] param([Parameter(Mandatory)][ValidateSet('Compliance Manager Administrators','Compliance Manager Assessors','Compliance Manager Contributors','Compliance Manager Readers')] [string]$RoleGroup, [Parameter(Mandatory)][string]$Member, [Parameter(Mandatory)][ValidateSet('Add','Remove')][string]$Action, [switch]$Commit, [switch]$WhatIf)

CMPMGR-Validation.ps1

Purpose: Collects the underlying technical signals that back automatable Compliance Manager improvement actions, so you can confirm the score reflects reality and produce evidence. Reports

whether: unified audit logging is enabled; DLP, retention, and sensitivity-label policies exist; and (via Graph) whether Conditional Access policies / an MFA posture are in place. Read-only — makes no changes. It does NOT read the Compliance Manager score itself (portal-managed, no public API); it validates the tenant state those actions depend on. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPMGR-Validation.ps1 powershell -ExecutionPolicy Bypass -File .\CMPMGR-Validation.ps1 -CsvPath C:\Temp\CM-Evidence.csv Requires ExchangeOnlineManagement (Connect-IPPSSession) and, for CA/MFA, Microsoft.Graph (Connect-MgGraph, scope Policy.Read.All). Sign in with a read-capable compliance admin. EXPECTED RESULTS A pass/absent line per signal (audit, DLP, retention, labels, Conditional Access), a note of which automatable actions each supports, and an optional CSV evidence snapshot. "Absent" means the control is not in place — the related improvement action should NOT be marked implemented. .NOTES Purview — Microsoft Purview Compliance Manager Implementation. Read-only. No credentials are stored. Enabling any of these controls is a separate, high-impact change owned by that feature's solution and piloted in simulation/test first — this tool only observes. Verify availability against your tenant. > [CmdletBinding()] param([string]$CsvPath)

How to run: powershell -ExecutionPolicy Bypass -File .\CMPMGR-Validation.ps1 powershell -ExecutionPolicy Bypass -File .\CMPMGR-Validation.ps1 -CsvPath C:\Temp\CM-Evidence.csv Requires ExchangeOnlineManagement (Connect-IPPSSession) and, for CA/MFA, Microsoft.Graph (Connect-MgGraph, scope Policy.Read.All). Sign in with a read-capable compliance admin. EXPECTED RESULTS A pass/absent line per signal (audit, DLP, retention, labels, Conditional Access), a note of which automatable actions each supports, and an optional CSV evidence snapshot. "Absent" means the control is not in place — the related improvement action should NOT be marked implemented. .NOTES Purview — Microsoft Purview Compliance Manager Implementation. Read-only. No credentials are stored. Enabling any of these controls is a separate, high-impact change owned by that feature's solution and piloted in simulation/test first — this tool only observes. Verify availability against your tenant. > [CmdletBinding()] param([string]$CsvPath)